

ANDRE VAN DER VEEN
THE NETHERLANDS

**SMART: STRUCTURED MULTI-DIMENSIONAL APPROACH TO RISK TAKING FOR
OPERATIONAL INFORMATION SYSTEMS *F8***

SMART

Structured Multi-dimensional Approach to Risk Taking
for Operational Information Systems

(SMART/OIS)

Risk Analysis Projectgroup:

A.M. van der Veen
D.P. de Jong
J.F. Bautz
N. Yousef Yengej
A.M.J. van Kempen
P.P.A. van Dam

Duyverman Computer Centrum
Free lance Information Consultant
N.V. R.C.C.
Ideta, KBB
NGI / SIG Information Security
Free lance Information Consultant

Abstract:

Since the day information systems became popular and essential tools, organisations were challenged by many new threats. The Risk Analysis Projectgroup, challenged by the confusion among management and specialists from the risk analysis area created a conceptual model. The model is based on systems development methodologies. The data model and process structure as part of the SMART/OIS concept, provide the tools to standardise and rationalise the risk assessment.

The projectgroup is constructing a prototype as part of the validation of their risk analysis model. Currently the model aims at operational information systems. The model, however, has the flexibility to serve other areas of risk analysis in the near future.

Key-words:

- ♦ risk analysis data model
- ♦ broad spectrum approach
- ♦ conceptual model

1. Introduction:

This paper contains the results of a research by a NGI projectgroup: "Risico-Analyse".

NGI stands for "Dutch Computer Society" and is a well-established and prominent community for informatics in the Netherlands. It promotes research regarding new areas, produces standards, publishes reports on specific items and organises meetings and conferences on IT. At present there are more than 40 different groups dealing with specific items within 10 different Special Interest Groups of NGI.

The "Risico Analyse" group consisted of specialists from commerce, industry and from governmental departments (Ministry of Defence).

The objectives of the "Risico Analyse" group were:

- evaluation of the current methods & tools for risk analysis
- formulation of a definition for the risk analysis and criteria for embedding within an organisation towards risk management
- creating a new model for integrated and structured approach to Risk Analysis. The model, besides a sound theoretical foundation, should be feasible for practical use.
- publication of the results at least within the Netherlands.

The scope of the SMART/OIS project was defined as following:

- SMART/OIS focuses on:
 - operational information systems,
 - data processing systems,
 - configuration (HW,SW, network,...)
 - data communication,
 - buildings,
 - staff,
 - etc.
- SMART/OIS model does not deal with the projectmanagement process, information planning, methodologies and techniques or internal audits, etc.

Our approach to this problem, given the above mentioned objectives, is described in chapter 2 of this paper. In chapter 3 a data model of the approach to Risk Analysis is presented. One of the sections of this model (section 0) will be presented in detail in Annex 1.

A process model of the Risk Analysis is dealt with in chapter 4. In chapter 5 the status quo, verification of the model and directions for further research are outlined.

2 Approach:

We have investigated a large number of methodologies and tools. This investigation led to the conclusion that the current methodologies and tools have serious limitations / disadvantages. The reason is that each methodology or tool focuses on a specific aspect of the broad spectrum of Risk Analysis. For instance, some of the methodologies concentrate only on the GOALS/OBJECTIVES, other only on DANGERS and some on the ORGANISATIONAL aspects.

This "small spectrum" approach, while excelling on a particular feature, does not take into account the remaining features. This might result in an unbalanced view or even misleading conclusion about risks.

Another observation of the group was that the methodologies are suitable either:

- in an indicative / qualitative manner, i.e the probabilities and the estimated amount of danger are expressed in terms of "low-average-high", or
- in a quantitative way, i.e the probabilities and the estimated impact of danger are calculated and presented with extreme precision. The relevance of this precision - in a small spectrum approach - is questionable.

The methodologies and the software packages / tools are (still) subject to criticism within the Risk Analysis community as illustrated by the following quotations from NIST 1989:

- "A major disadvantage is that there is no standard method or agreed upon approach for performing risk analysis."
- "There is no assurance that any particular method is complete or accurate."

We were confronted with the following questions / dilemma's:

- Shall we spend more time drilling down into the literature hoping to find still another broad spectrum methodology / approach that covers more than one dimension / aspect?

The probability to find one was considered to be negligible since the investigation covered the literature thoroughly.

- Shall we take one of the approaches and try to adapt / enhance this towards perfection?

This option was also rejected as a perfected approach would contribute to in-depth coverage of the details but would not broaden the "small spectrum".

- Why not using two or more approaches simultaneously for Risk Analysis?

Due to the costs associated with a risk analysis in a real life situation, the benefits of this option were not likely to exceed the costs. So this also was no solution to the problem!

By the end of our investigation the conclusion was that the small spectrum nature of the current approaches is strongly reflected in the set of the (input) data needed for estimation and calculation purposes. The required set of data although large in number and very detailed, contains information about one single aspect of risk.

The consequence of this small bandwidth is that the output result (prediction) also covers only a small range of risk aspects.

This property is characteristic for a methodology or tool and can be used as a "finger print" profile to identify and classify the methodologies and tools.

A typical "finger print" is shown in figure 1.

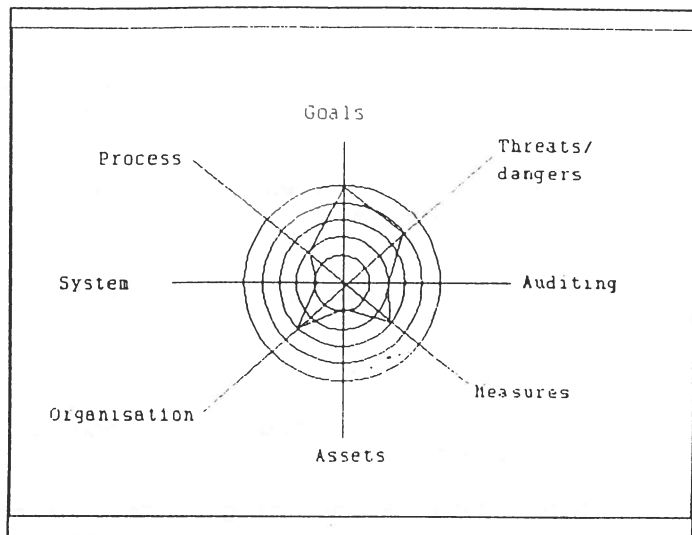


Figure 1: Finger prints of a current approach. The distance along the radius represents the amount of data and the level of detail associated with a specific dimension.

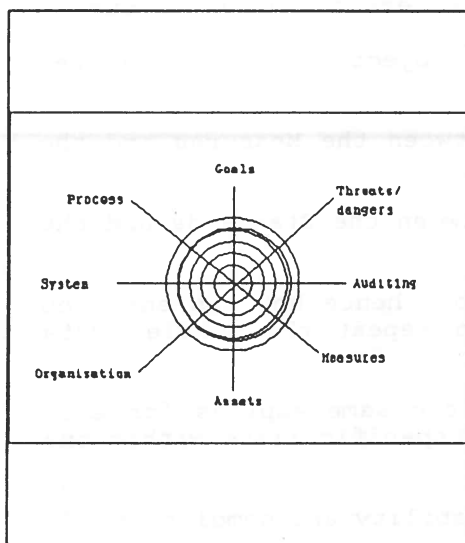


Figure 2 : Ideal profile for analysed organisation

The finger prints of the current approaches show a clear preference for a single dimension instead of a more balanced coverage of all dimensions. This is illustrated in fig 2.

This observation provided a clue to the solution of the problem: Select a set of current approaches, each excelling in one aspect, integrate them into a "meta-approach". Result is a balanced approach which covers all the dimensions and to a high extent.

This is the basic philosophy behind "SMART/OIS" concept.
But this led to the following problems:

- due to the large number of existing approaches, one is faced with a huge number of data, to be considered! (caused by the vastness and level of detail)
- there are no guidelines or standards for the classification of the data. Each approach employs its own definition or criteria for clustering the data.

An integrated approach has the advantage of "taking the best out of current methodologies en tools".

Some of the benefits are:

- there are various mathematical models for calculating and dealing with uncertainties.
- the input data can be assigned to different people within a branch
- the output is mainly graphically oriented instead of texts / lists.

Nevertheless there were still issues left over, subject to fundamental research:

- What are the differences, commonalities between the **Measures** and the **Properties**? How to deal with these?
- What are the differences, commonalities between the **Standards** and the **Requirements**? When and which one to use?
- Risk analysis is not an incidental operation; hence how can one keep the results up to date, without having to repeat the (whole) data entered.
- Each branch of business has its own risks; the same applies for each system platform. So, how to integrate these specific risks within one single system?
- How to calculate a reliable outcome of probability and demolition?

To deal with this complex problem, the everyday "natural" language, being a common practice in the Risk Analysis area has to be broadened. The natural language has shortcomings and is not adequate to tackle this problem. So we need more formalised "languages" and / or instruments.

We were faced with the question to either develop such an instrument or to search for an existing one!

As far as calculations are concerned, there was already an instrument: the mathematics employed by the current approaches.

But this is only a part of the solution. Hence an additional instrument was needed to handle the (amount and the level of detail of) data for all the current approaches.

Since, within IT there are numerous methods for analysing and modeling data and processes, we "borrowed" our instruments from the IT systems development and applied them to Risk Analysis.

We believe that there is similarity between the development of a risk analysis package and the development of an information system in general.

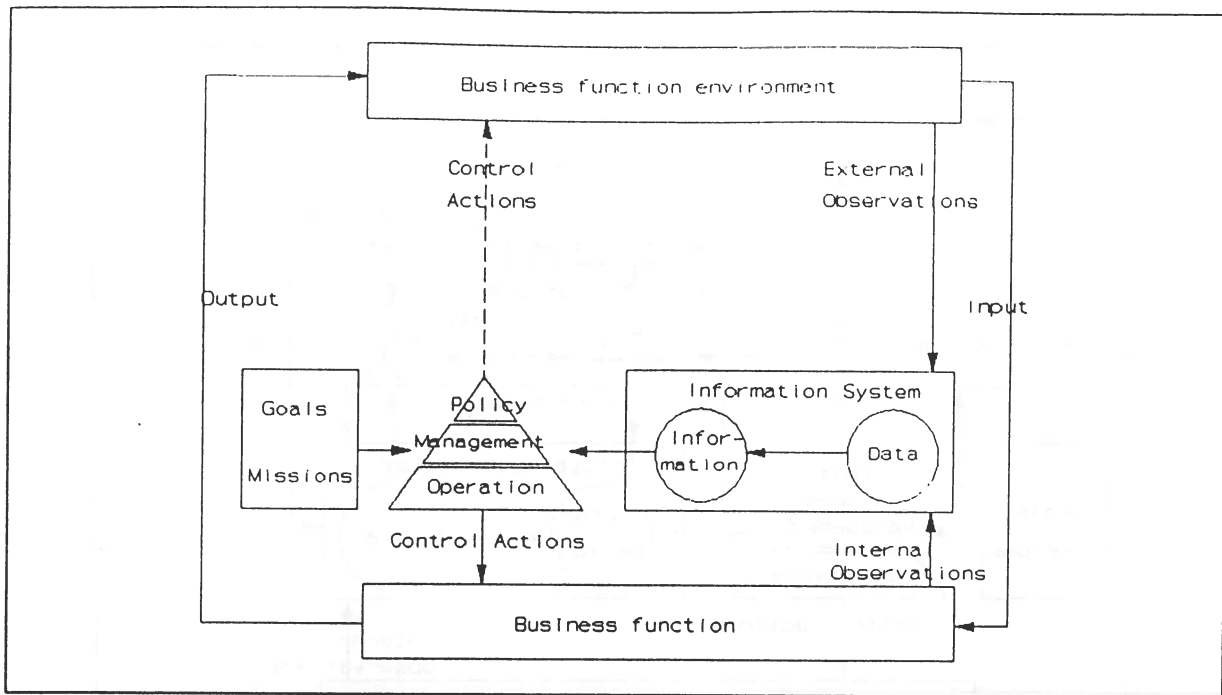


Fig. 3: Generalised model of an information system according to Sherman C. Blumenthal

The business function in fig.3 interacts with its environment (accepts inputs and produces outputs).

The information system acquires data from the business function and from the environment and processes this into information (Critical Success Factors) for the managing (controlling) unit.

This managing unit generates actions:

- to steer the business function, and
- to manipulate the environment (e.g. advertising), according to the output of the information system and a set of (business) objectives.

From the viewpoint of risk analysis the information system (IS) by itself is also a "business function" being managed by another managing unit; the later controls according to the information produced by a risk analysis information system (SMART/OIS), and the set of (business) objectives. The IS interacts with its own environment.

This two-level nesting control concept, (Figure 4) in combination with the Bachman and DFD method, and the propagation of damage appeared to be suitable for describing SMART/OIS.

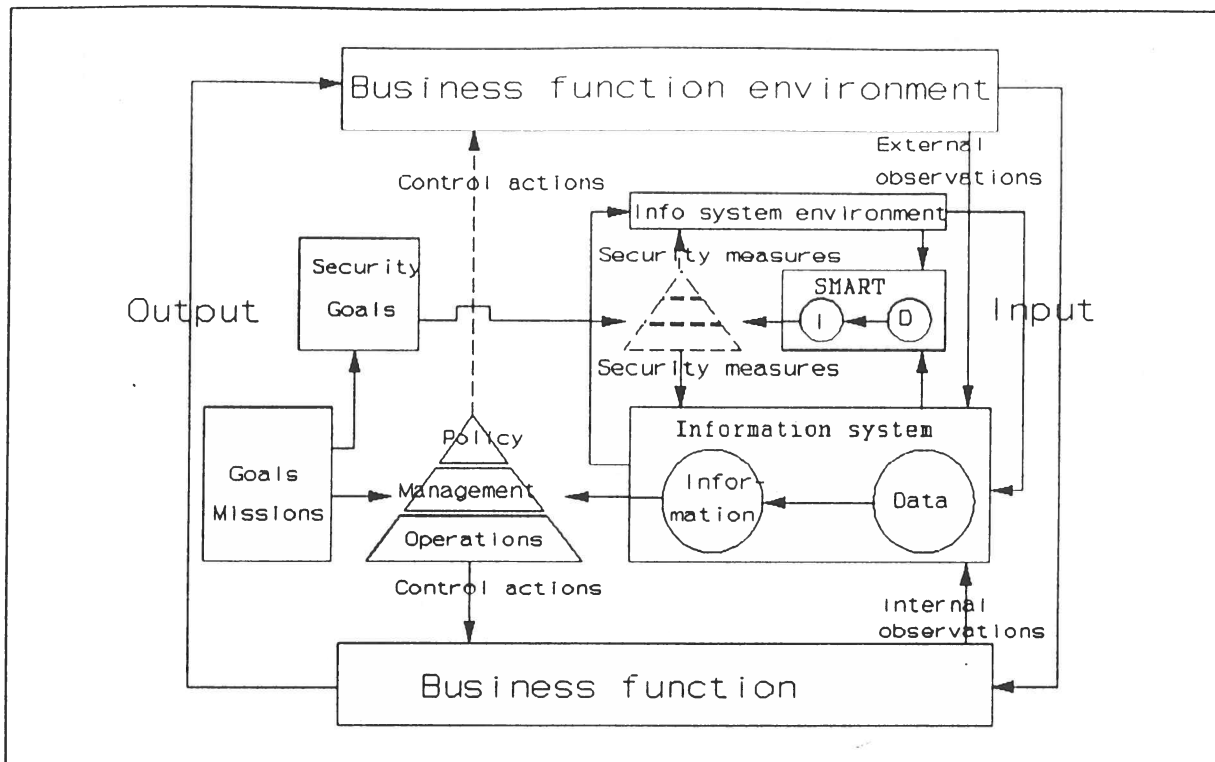
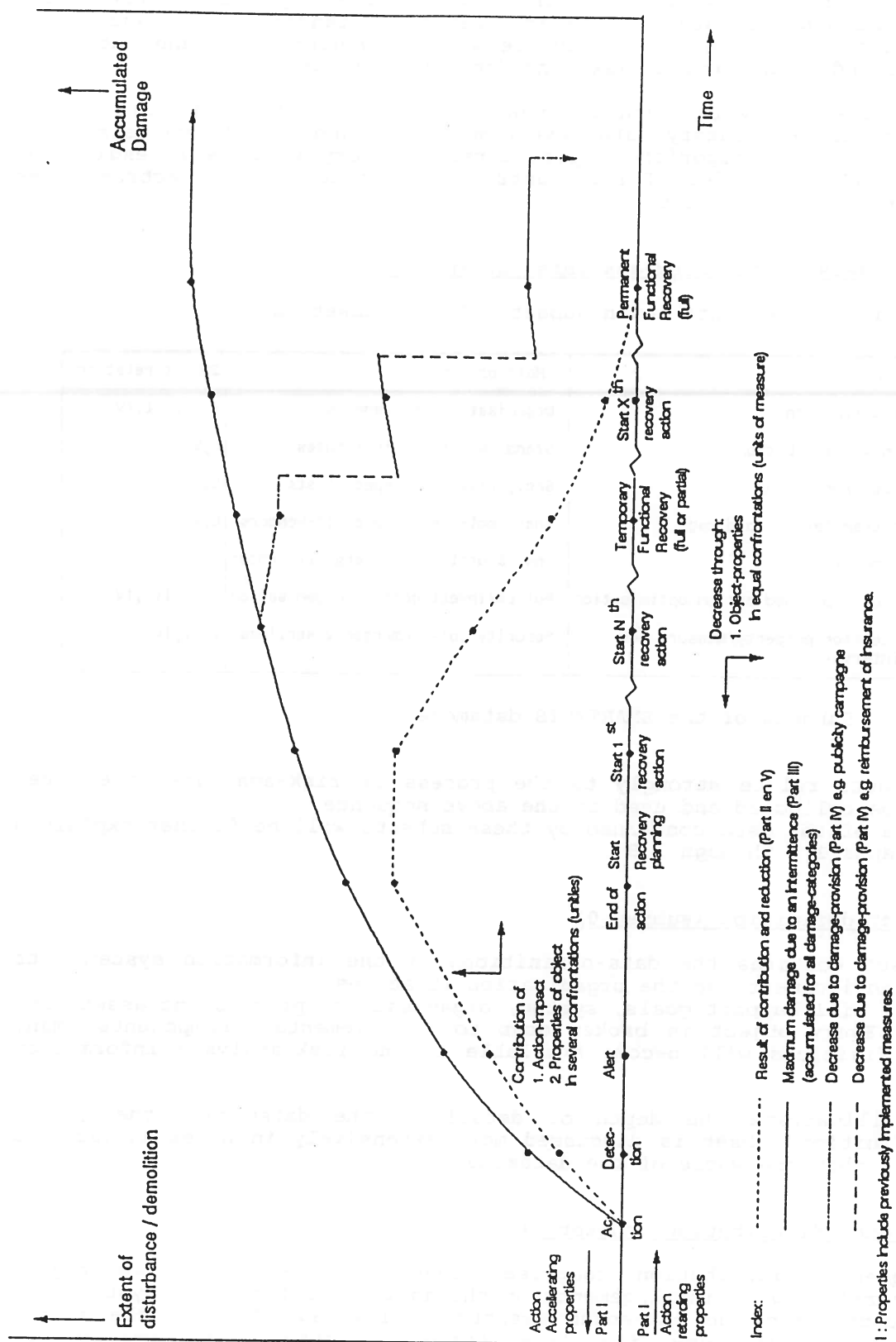


Figure 4: Control concept for risk analysis of one operational information system

The general model applied to the evolution of unwanted events into confrontations resulting in demolition and damage is as the following:
(see next page)

Fig. 51 Propagation of damage as a function of time



3 Data model of SMART/OIS:

As has been stipulated earlier, the number of data needed for risk-analysis is huge. As risk-assessment knowledge on specific situations rests with specialists in their particular area, data will have to be collected, estimated and standardised by those specialists.

Data for generic use will also partly be provided by specialists. Large parts of the generic data will be acquired from standardisation and certification institutes. The most valuable are the generic data and the algorithms applied to determine risks and demolition impacts.

Existing risk analysis methodologies, therefore have a place in the proposed model. Elementary data, event modelling and impact analysis techniques, as well as algorithmic procedures may very well be re-engineered into the SMART/OIS-model. Participants will gain a "broad spectrum" risk analysis information system.

3.1 The subsets of the risk-analysis data-model

The model is divided into seven subsets. These subsets are:

	Description	Main providers	Subset relations
0	Object definition	Organisation, IT-vendors	I,II,III,IV
I	Frequency distribution	Stand. & certif. institutes	0,V
II	Event confrontation	Sec., risk, ins. specialists	0,V
III	Impact translation to damage	Ins-, pol-, stat-spec, IT-vendors	0,V
IV	Damage provision	Ins. & util co's, emerg, IT-vendor	0,V
V	Consciously planned action optimisation	Police/investigators, organisation	I,II,III,IV
VI	Resources for property/measure per time interval	Security co's, emergency services	I,II,IV

Fig 6: Subsets of the SMART/OIS datamodel

These subsets relate strongly to the process of risk-analysis, i.e. they ought to be collected and used in the above sequence. The nature of the data contained by these subsets will be further explained in paragraphs 3.2 through 3.8.

3.2 Object definition (subset 0)

This subset contains the data-definitions of the information system, its relevant environment and the organisation it serves. These data will support goals, system, organisation, process and assets approaches. Every object is broken down to its elementary components. Many object definitions will become available in the risk-analysis information base.

- To illustrate the depth of detail in the datamodel, the object definition subset is discussed more extensively in Annex 1. Annex 2 will show the whole of the datamodel.

3.3 Frequency distribution (subset I)

The frequency distribution comprises question, answer and key-figure libraries relating to infringements on the analysed information system. The library containing the "unwanted events" is leveled. Many of the events that we use in every day life, like strike by lightning or power-outage,

have to be broken down in a set of more elementary actions. E.g. strike by lightning breaks down to:

- ball-lightning
- vertical lightning
- forked lightning
- sheet lightning

A new, more detailed level may follow, e.g. "forked lightning" may be followed by:

- what is the height of the building the information-system resides in? (object property)
- which object (and their heights) are found in the environment?

Questions will have to be completed regarding circumstances which may accelerate or retard unwanted events. These circumstances influence the frequency with which an unwanted event occurs.

In this subset you will also find descriptions of the perpetrator. Characteristics of perpetrators are needed because the methods applied differ from the "simple" acts of God. Intended violation creates a large number of possible confrontations for the risk manager.

Key figures will be stored to indicate the frequency change that relates to 1 question, 1 answer and 1 event. The key figure itself may be composed from answers to subquestions.

3.4 Event confrontation (subset II)

This subset includes the confrontation processes, triggered by the relevant "unwanted actions" from the previous paragraph. The confrontation process is uniquely identified by its name and the unity it is measured in.

In this subset you will find entities that define the downgrading of objects in time. The height of the impacted action, the contributing and decreasing properties and measures result in demolition. The result is calculated as a maximum demolition impact / potential for:

- 1 category of demolition
- 1 object
- 1 perpetrator
- a chosen interval of time.

3.5 Impact translation to damage (subset III)

In this section you will find data concerning the translation of demolition, i.e. where known properties (including previously installed measures) are taken into consideration. The section provides standard damage amounts of events. With these data and the deterioration capability (3.4) SMART/OIS will calculate the real damage per occurrence(group). The consequences of consciously planned actions (by perpetrators) are not yet compensated here.

3.6 Damage provision (subset IV)

The data in this subset focuses on the background of events affecting the information system. The cause of any action that may inflict improper functioning of the information system has to be identified. The cause of action may lead to in- or exclusion in assurance-policies; a single data-file may only be recovered if the back-up technique allows for it. So, in order to calculate the risk-value, while taking contributing / decreasing measures and properties into account, one needs to know the origin of the event.

3.7 Optimising for planned actions (subset V)

In this section data relating to the scenarios an perpetrator might have in mind, are collected.

While defining these data one has to keep in mind any objective an perpetrator may have. Aspects that have to be defined are:

- perpetrator's insight into his (supposed) goals
- alternative actions the perpetrator might consider
- tools / methods that the perpetrator may use to reach his goals

3.8 Resources for property/measure per time interval (subset VI)

This datamodel subset relates to subsets I, II and IV. This subset contains the actual situation of how measures are implemented and maintained and how properties are made productive.

3.9 Steady states and simulations with the SMART/OIS datamodel

Properties and measures are interchangeable. Properties describe an object-state. When a property is changed for reasons of security or reliability, it becomes a measure. Measures will be added as changed properties to a separate copy of the SMART/OIS database.

Thatch may be a property of a building. As we change the roofing to tiles, for fire-prevention purposes, the tiles become the changed property (whether implemented or not).

4 Process model of SMART/OIS:

In fig. 7 the major activities concerning the risk management of an enterprise are shown. The risk analysis (activity no. 2 and 5) is found here to be, although important, only a part of the range of activities.

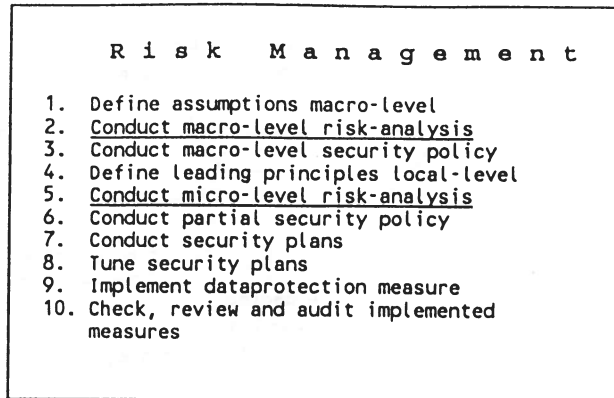


Figure 7: activities in a full security cycle

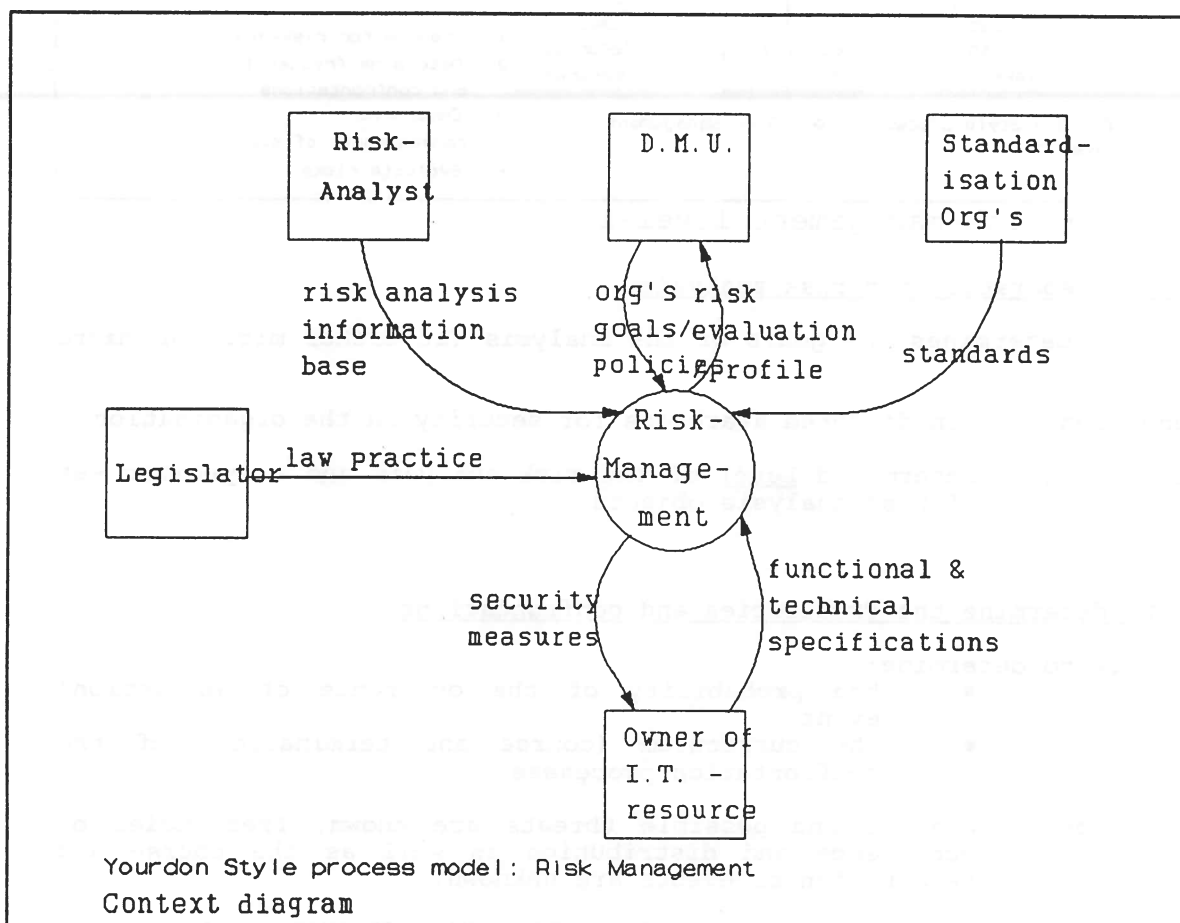


Figure 8: Context level of the risk-management primary process

The context diagram of the risk management, according to SMART/OIS is presented in figure 8 (D.M.U.: Decision Making Unit).

More details are shown in figure 9; the four processes (transformations) are discussed in the full wing

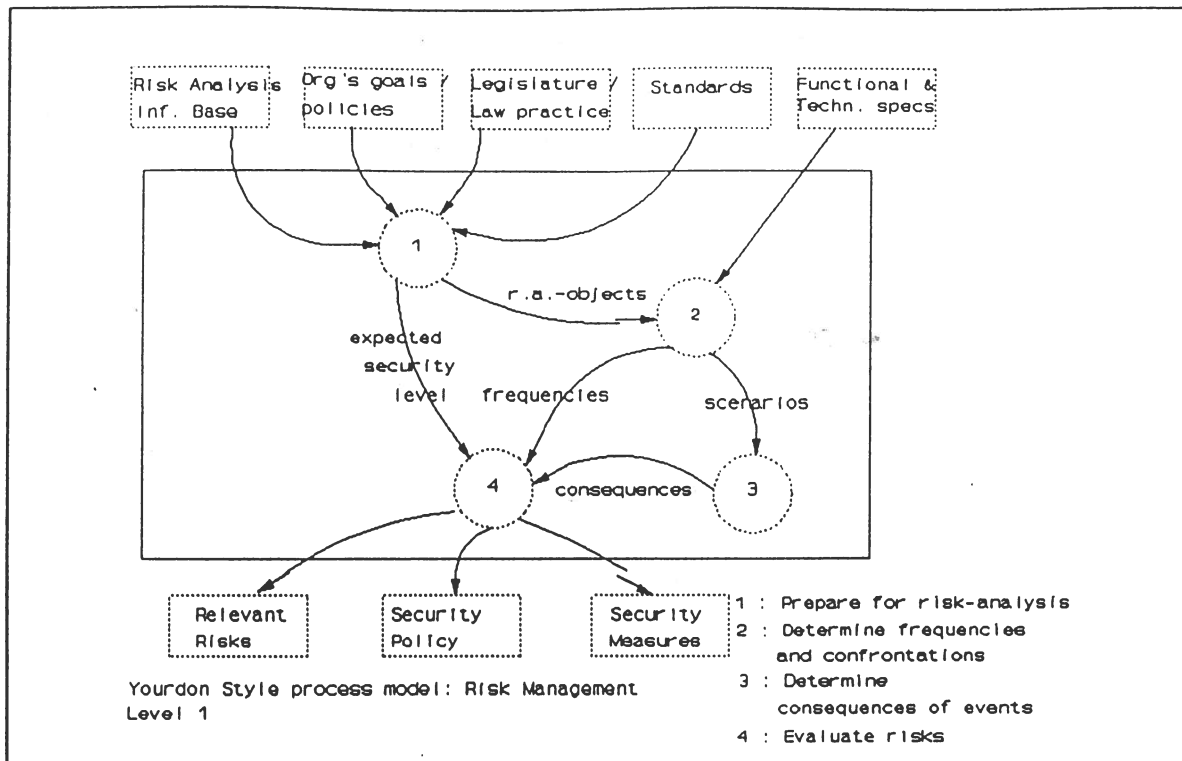


Figure 9: Risk-management level-1

Proces 1: preparation for risk analysis

The process determines the goals of the analysis (at either micro or macro level).

Pre condition: Non-directed awareness for security in the organisation

Post condition: Determined Level of the risk analysis and a specific set of risk analysis objects

Proces 2: determine the frequencies and confrontations

The goal is to determine:

- the probability of the occurrence of an action/event
- the curriculum (course and termination) of the confrontation processes

Pre condition: Objects and possible threats are known, frequencies of occurrence and distribution as well as the course and termination of events are unknown.

Post condition: Objects, threats, frequency distribution and course/termination of events are known.

Proces 3: determine the consequences of events

The goal is to determine the characteristics of an action, taking into account the contributing and decreasing measures and properties of the object.

Pre condition: Unwanted actions and their occurrence are known.

Post condition: Fully determined course and termination of unwanted events (including financial damage).

Proces 4: Evaluate risks

The goal is to determine the risk; where risk is defined as the probability that an action occurs together with a corresponding demolition and consequential damage.

According to the appropriate risk level, the risk will either be considered relevant or the analysis ought to be repeated.

Pre condition: Risks to selected objects known, measures to be raised against these risks unknown.

Post condition: Security measures to be raised determined, security policy adjusted.

5 Concluding remarks:

The conceptual SMART model, as far as theory is concerned, is fairly completed. It is a general concept, although primarily aimed at the information systems, it is potentially applicable to many areas where risk analysis and risk management are involved.

The next step will be the validation of this model. To this end we are presently building a prototype of a risk analysis information system. This prototype concerns the operational information systems and hence the name: SMART/OIS.

Future trend:

Due to the characteristic/abstract approach of the SMART model, we are convinced that it can be employed (with additions and adjustments) in the following areas:

- Oil- drilling industry
- Civil Engineering & Construction
- (Chemical) Process industry
- Economy & business areas

We shall be investigating these possibilities in the near future; we shall wellcome every support or participation.

Annex 1: Object Definition subset

Purpose of this annex is to show the level of detail to which all the subsets have been decomposed. The level of detail is illustrative for the other parts of the data model.

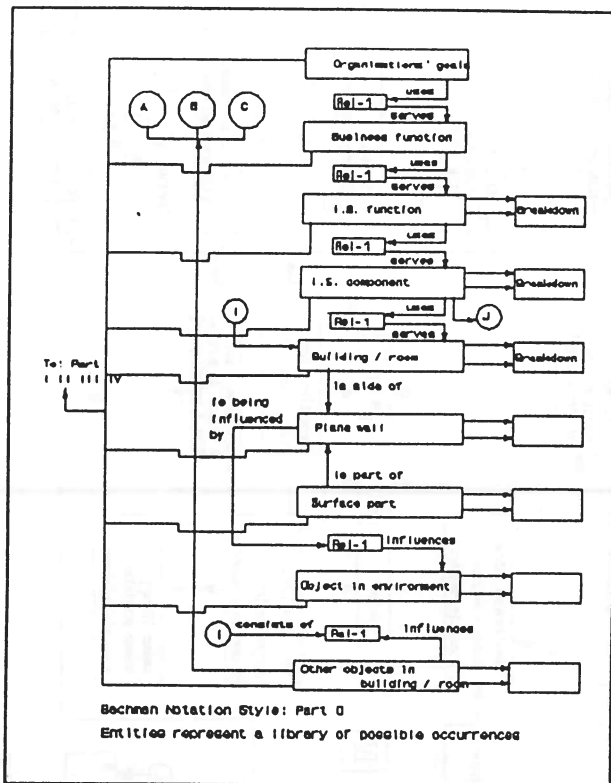


Figure 10: Object definition subset

The system will contain a number of standard libraries of components and the environment of an information system.

The risk analyst will pick from these lists what he finds in the reality to be analysed.

The risk analyst will enter organisational goals, business functions and information system functions (e.g. menu items, lists) that he finds within the scope of the analysis.

The information system functions will be decomposed to their components. The relations between the parts will be defined. (e.g. menu item A depends on cable x, modem y, server 4 and personal computer/terminal 126).

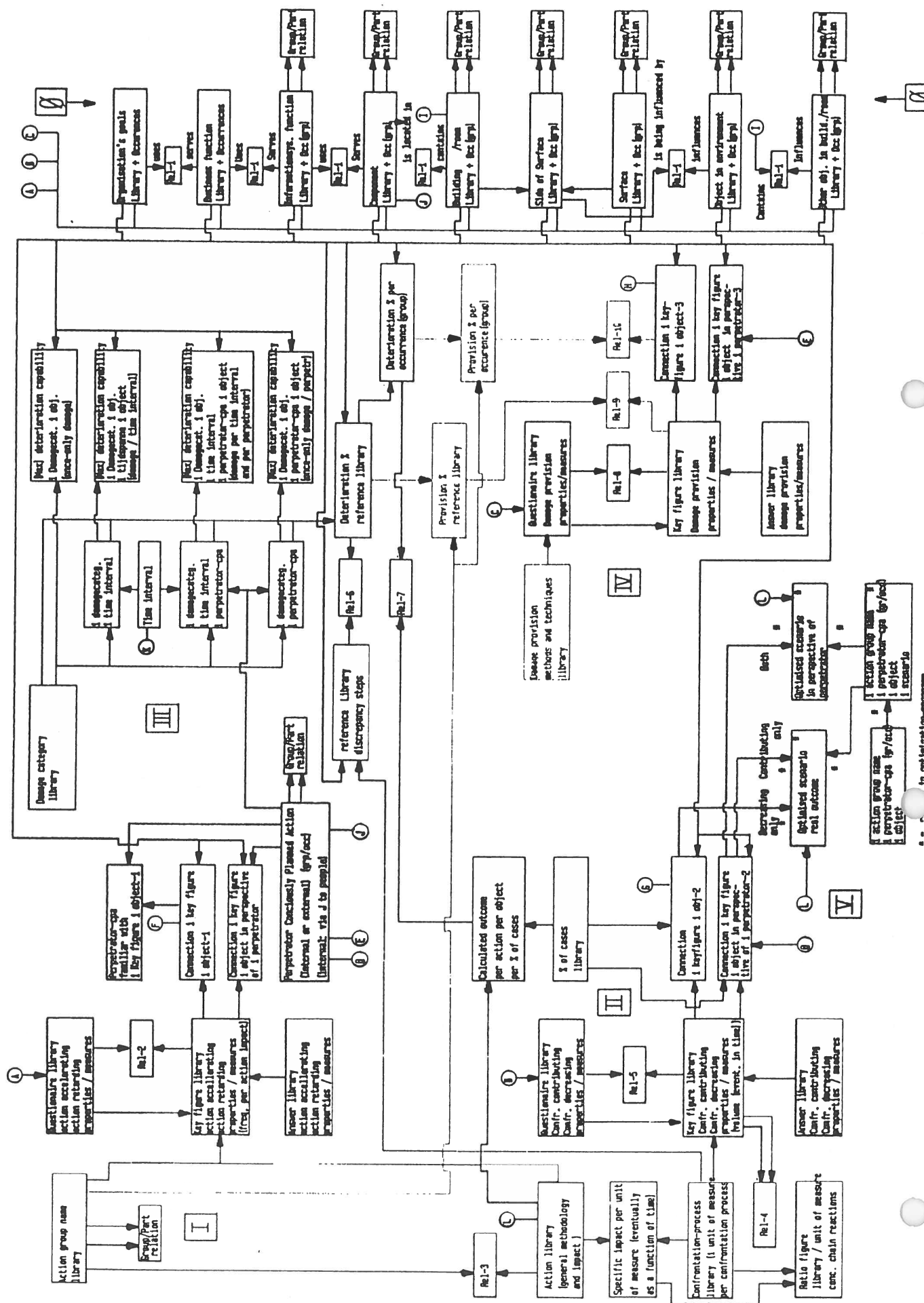
The next step is to describe the rooms which information system parts use or reside in. So, not only the computer centre is involved but the rooms that contain con-

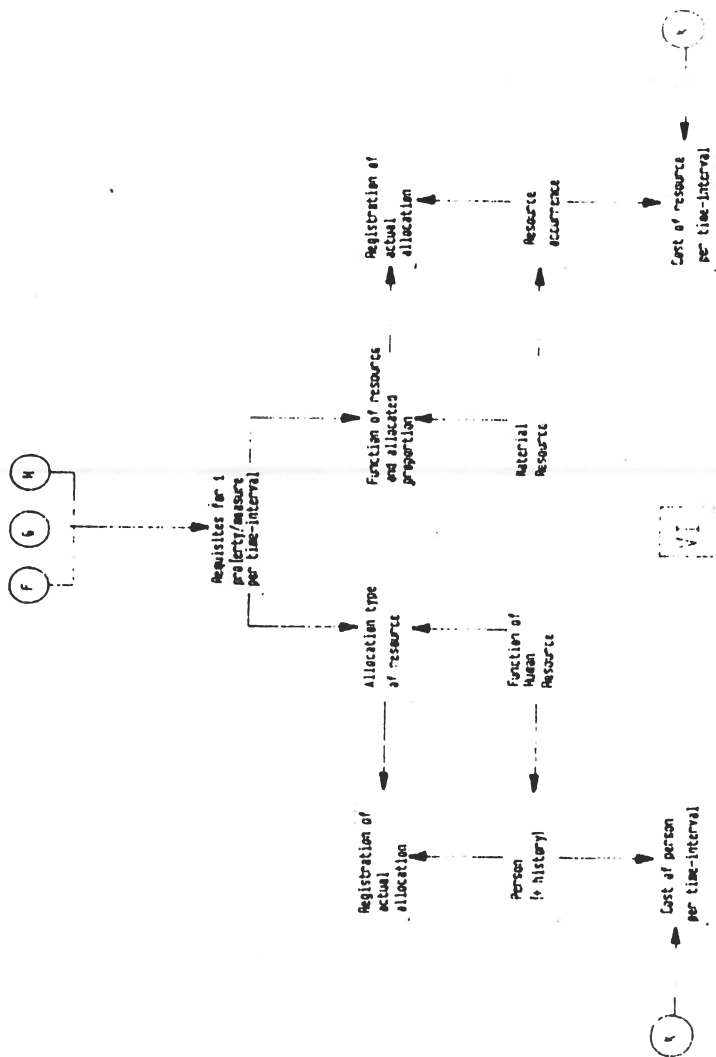
nected terminals and p.c.'s and the rooms through which cabling leads as well.

In these rooms objects may be present, that contribute to or limit unwanted events that may take place. Those also have to be taken into consideration.

A room depends on several surface sides (walls + ceiling + floor), each surface side is part of 1, 2 or more rooms. That is why the risk analyst has to break down the wall into surface parts. These surface parts may be subjected to different threats from the environment.

The connectors A, B and C relate the objects and their group/parts relations to the questions applicable to these objects.





© N6I Projectgroup Hisico analyse 1992.

References

Guide for selecting automated risk analysis tools
NIST, 1989

Computer security publications
NIST, 1990

Bestuurlijke informatiesystemen en automatisering
Prof. Dr. T.M.A. Bemelmans, 1987

Risico-analyse en risico-management
Nederlands Genootschap voor Informatica, 1992